INFORMATION SECURITY · PORTFOLIO

송승찬



공격자의 방식으로 검증하고,
법과 데이터로 위험을 설명합니다.

AI 챗봇의 개인정보 유출을 진단하는 도구 RAG-DIAG를 만들어 특허로 출원했고, 시스템 해킹과 웹 모의침투를 실습하며 공격과 대응을 함께 익혔습니다. 찾은 취약점은 재현 과정과 대응방안까지 문서로 남깁니다.

chanchan3314@naver.com 010-7406-3317 github.com/seungchan-song 2001.01.04

학력	세종대학교 정보보호학과 (2021.03 – 2027.02 졸업 예정) · 학점 4.10 / 4.5 상산고등학교 (2017.03 – 2020.02)
자격 · 어학	정보보안기사 (2026.08) · TOEIC 850 (2026.02) · OPIc IH (2026.09)
해외 경험	Shenzhen Funful Bilingual School · 중국 선전 (2006.04 – 2009.07) Green Oasis School · 중국 선전 (2009.11 – 2011.10) UBC Blockchain Summer Institute · 캐나다 밴쿠버 (2026.08)
외국어	영어 능숙 · 중국어 중급
주요 기술	언어 · 환경: Python · C · Linux AI 보안: RAG · Haystack · FAISS 보안 점검: Burp Suite · Nmap · Nikto · GDB · pwntools
병역	공군 복무 (2023.04 – 2025.01)

PATENT
특허 출원
RAG 정보 유출 취약점 진단

AWARD
장려상 (3등)
캡스톤 경진대회

PROGRAM
Elite Top 3
빡공팟 시스템 해킹

프로젝트

01	**RAG-DIAG**	AI 챗봇 개인정보 유출 진단 도구 · 특허 출원	p.2
02	**교육용 쇼핑몰 모의침투**	블랙박스 웹 모의침투 · 5개 항목 진단	p.3
03	**Health Access Registry**	UBC 블록체인 해커톤 · 의료기록 열람 서비스	p.4
04	**보이스피싱 레이더**	피해 통계 · 수법 분석 자동화	p.5
05	**빡공팟 시스템 해킹**	12주 과정 · Elite Top 3	p.5

PROJECT 01 · AI 보안 진단

RAG-DIAG

github.com/seungchan-song/RAG-DIAG ↗

AI 챗봇(RAG)의 개인정보 유출을 진단하는 CLI 도구

기간	구성	역할
2026.03 – 2026.08	4인 팀 · 세종대 캡스톤 디자인	팀장 · 탐지 · 판정 · 위험도 설계

문제와 목표

문서를 검색해 답하는 AI 챗봇은 내부 문서에 든 개인정보를 답변으로 그대로 내보낼 수 있습니다. 공격 질문을 자동으로 보내고, 답변에서 개인정보를 찾아 위험도를 측정하는 진단 도구를 만드는 것이 목표였습니다.

수행 과정 · 나의 기여

01 팀장 · 일정과 회의 운영

3개월 WBS로 역할과 마감을 나누고, 주간 정기 회의는 진행 점검에, 예비 회의는 새 안건 결정에 쓰도록 나눠 운영했습니다.

02 한국형 개인정보 4단계 탐지

영어권 기준 도구는 주민등록번호 같은 한국 개인정보를 놓칩니다. 정규식 → 체크섬 검증 → NER 모델 → sLLM 교차 검증의 4단계로 탐지하고, 이를 바탕으로 공격 성공 판정 기준을 만들었습니다.

03 시나리오를 비교할 수 있는 위험도

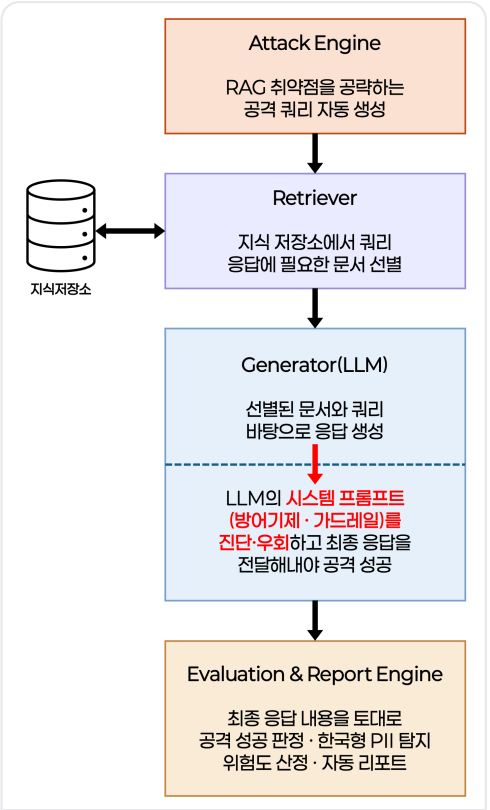
개인정보 탐지 건수만 세면 주민등록번호와 전화번호 유출이 같은 위험이 됩니다. 개인정보보호법을 참고한 심각도와 공격 성공률을 한 점수로 합쳐, 공격 4종을 같은 기준으로 비교하고 대응 우선순위를 정할 수 있게 했습니다.

04 대조군 실험 제안

공격 질문만 보내면 평범한 질문에도 나왔을 유출까지 공격 효과로 잡힙니다. 일반 질의를 대조군으로 두어 공격이 추가로 만든 유출만 측정했습니다.

05 문서화 총괄 · 특허 출원

설계 문서 작성을 총괄하고, 발명 설명서와 선행기술 대비 차이점을 직접 작성해 특허 출원까지 이끌었습니다(공동 발명자).



구조도

결과

PATENT

검색 증강 생성 환경에서의 정보 유출 취약점 진단 시스템 및 방법

출원번호 10-2026-0164171 · 출원일 2026.08.31

출원인 세종대학교산학협력단 · 심사 청구, 등록 심사 중

AWARD

장려상 (3등)

캡스톤 경진대회 · 2026.06

OPEN SOURCE

대회 출품

2026 오픈소스 개발자대회

PROJECT 02 · 웹 모의침투

교육용 쇼핑몰 웹 모의침투

실습용으로 구축된 가상 쇼핑몰 웹 서비스를 블랙박스 방식으로 점검하고 결과보고서로 정리

기간	구성	역할
2026.10.28 – 10.29	7인 팀 · SK쉴더스 루키즈 35기	5개 항목 진단 · 대응방안 작성

문제와 목표

OWASP Top 10과 KISA 주요 취약점을 바탕으로 한 17개 분류 30개 점검 항목을 팀원이 나눠 맡아, 정보 수집부터 실제 공격과 대응방안까지 담은 결과보고서를 만드는 것이 목표였습니다. 저는 서버 설정과 정보 노출, 개인정보보호법 적절성 등 5개 항목을 맡았습니다.

수행 과정 · 나의 기여

정보 수집 → 취약점 분석 → 침투 테스트 → 영향 분석 → 대응방안

점검 항목	확인한 내용	대응방안
중요정보 평문전송	개인정보 수정 요청에 아이디 · 비밀번호가 평문으로 담겨 전송됨, 관리자 페이지에 주문자 IP 노출	HTTPS 강제 전환, 쿠키 Secure · HttpOnly · SameSite 설정
불필요한 페이지	DIRB · Nikto로 인증 없이 열리는 phpinfo.php 발견, PHP · OS · 커널 버전과 설정 경로 노출	진단용 페이지 삭제, 꼭 필요한 페이지는 인증 · 접근 IP 제한
테스트 · 데모 페이지	백업 확장자 · robots.txt · 리스팅 경로까지 함께 확인, 운영에 불필요한 phpinfo.php를 삭제 대상으로 판정	테스트 · 데모 페이지 정리, 디렉터리 리스팅 차단
서버 보안 설정	응답 헤더로 Apache · PHP · OpenSSL 버전과 WebDAV 노출, 주요 보안 헤더 누락, TRACE 메서드 허용	버전 정보 숨김(ServerTokens · expose_php), TRACE 차단, 보안 헤더 적용
개인정보보호법 적절성	주민등록번호 수집 · 평문 전송, 솔트 없는 비밀번호 저장, 동의 미분리 등 미흡 사항 7건을 법 조항(제22조 · 제24조의2 · 제29조 · 제30조)과 대조	주민번호 수집 폐지, 전송 · 저장 암호화, 화면 마스킹, 동의 분리, 처리방침 정비

사용 도구: Burp Suite · Nikto · DIRB · Nmap

결과

TEAM
172건
팀 전체가 찾은 취약점 (High 53건)

MINE
담당 5개 항목
평문전송 · 불필요 페이지 · 테스트 페이지 · 서버 설정 · 개인정보보호법

COMPLIANCE
7건
개인정보보호법 조항과 대조한 미흡 사항

PROJECT 03 · UBC 블록체인 해커톤

Health Access Registry

github.com/seungchan-song/blockathon ↗

환자가 본인 의료기록의 열람 권한을 직접 관리하고, 모든 열람 시도를 위 · 변조할 수 없게 남기는 서비스

기간	구성	역할
2026.08 · 캐나다 UBC	4인 · 한국 · 스위스 · 중국	팀장 · 서비스 구조 설계 · 배포

문제와 목표

의료기록 열람 기록은 병원이 관리합니다. 환자는 누가 본인 기록을 열람했는지 알려면 해당 병원에 요청할 수밖에 없고, 기록이 수정 · 삭제되어도 알아차리기 어렵습니다. 위 · 변조할 수 없는 공개 장부인 블록체인에 열람 권한과 열람 시도를 기록해, 환자가 직접 확인할 수 있는 서비스를 목표로 했습니다.

수행 과정 · 나의 기여

01 첫 설계의 문제 제기

처음 안은 암호화한 진료 기록을 블록체인에 올리는 것이었습니다. 한 번 올린 정보는 지울 수 없어, 암호화해도 환자의 삭제 요청에 응할 수 없다는 문제를 제기했습니다.

02 체인에 올릴 범위 결정

"지울 수 있어야 하는 것은 체인 밖에 둔다"는 기준으로, 체인에는 허용한 주소와 열람 시도만 남기고 이름 · 진단 · 병력은 올리지 않았습니다.

03 관리자 권한 제거 · 거절도 기록

관리자 권한이 있으면 환자 모르게 권한이 바뀔 수 있어 없애고, 환자 지갑만 권한을 바꾸게 했습니다. 거절된 시도까지 남겨 단순한 접근 목록이 아닌 감사 기록이 되게 했습니다.

04 AI 활용 개발 · 직접 검증

코드는 AI 도구로 작성하되, 무엇을 체인에 올리고 누구에게 권한을 줄지 설계 기준을 가이드라인으로 먼저 정리해 전달했습니다. 권한 부여 · 회수 · 거절 기록이 의도대로 동작하는지 시나리오별로 직접 검증하는 데 시간을 들였습니다.

한계와 다음 단계

의사 신원 확인

지갑 주인이 실제 의사인지는 확인하지 못합니다. 검증 가능한 자격증명(VC)을 붙이면 컨트랙트를 바꾸지 않고 보완할 수 있습니다.

열람 관계 노출

이름과 진단은 숨겨도 주소와 시각은 공개됩니다. 영지식 증명으로 누가 봤는지 드러내지 않고 열람을 검증하는 방향을 제시했습니다.

결과

DEPLOYMENT

테스트넷 실배포

Sepolia에 배포해 거절 → 허용 → 체인 로그 확인을 실시간 시연

PROJECT 04 · 데이터 자동화

보이스피싱 레이더

github.com/seungchan-song/voicephishing-radar ↗

기간 **2026.09 – 2026.10** 구성 **6인 · SK쉴더스 루키즈** 역할 **팀장 · 구조 설계 · 통합**

문제와 목표

보이스피싱의 지난 피해는 경찰청 통계로 연령 · 지역 · 연도별로 분석하고, 지금 유행하는 수법은 뉴스로 모아 앞으로의 피해를 막는 정보로 쓰고자 했습니다. 두 자료를 매주 자동으로 수집 · 분석해 전달하는 것이 목표였습니다.

수행 과정 · 나의 기여

01 결과를 한 파일로 모은 설계

통계와 뉴스를 분석 · 처리한 결과를 result.json 하나로 모으고 웹 · 메일 · Notion은 이 파일만 읽게 해, 기능별로 따로 개발하고 수정하기 용이하게 했습니다.

02 수집부터 전달까지 자동화

공통 코드와 통합 실행 스크립트를 맡아, 크롤링부터 대시보드 · 메일 · Notion 갱신까지 매주 월요일 자동으로 실행되게 했습니다.

03 역할별 출력 3가지

대시보드는 현황 조회, 경보 메일은 새 수법 알림, Notion은 주차별 기록 보관으로 출력의 역할을 나눴습니다.

배우고 성장한 점

파이프라인 단위의 자동화 설계

크롤링 · 분석 · 시각화 · 알림을 하나의 파이프라인으로 묶고 정기 실행까지 연결하며, 처음부터 자동화를 전제로 구조를 짜는 법을 익혔습니다.

설계 결정에 근거를 남기기

결과 파일을 하나로 둔 이유(개발 용이성)와 출력을 셋으로 나눈 이유(역할 분리)를 README에 남겨, 누구나 구조를 이해하고 기능을 이어 붙일 수 있게 했습니다.

PROJECT 05 · 시스템 해킹

빡공팟 13기 시스템 해킹 (RED 코스)

기간 **2025.06 – 2025.08** 형태 **개인 · 12주 과정** 수료율 **31.8%**

학습 목표

공격자가 프로그램의 메모리를 다루는 원리를 이해하고, 보호기법이 적용된 바이너리를 직접 분석해 공략할 수 있는 실력을 갖추는 것이 목표였습니다.

수행 과정

01 메모리와 실행 구조

스택 · 힙 구조와 어셈블리, 실행 파일 포맷을 익히고 GDB(pwndbg)로 실행 흐름을 직접 따라가며 분석했습니다.

02 공격 기법과 취약점 분석

버퍼 오버플로우와 ROP를 워게임으로 재현하며 보호기법 우회 원리를 익히고, 퍼저와 코드 오디팅으로 취약점을 찾는 법을 실습했습니다.

03 학습 기록 정리

12주간 공부한 이론과 과제 풀이를 모두 Notion에 기록하고, 자주 쓰는 기법은 따로 모아 '포너블 백과사전'으로 정리했습니다.

결과 · 배운 점

RESULT

Elite Top 3

수료생 중 상위 3명

LESSON

공격 원리에서 방어 기준으로

메모리가 어떻게 조작되는지 직접 재현해 보니, 코드에서 경계 검사와 입력 검증이 빠진 곳을 먼저 보게 됐습니다.

TIMELINE

연혁

● 수상 · 성과 ○ 프로젝트 ○ 자격 · 어학 ● 진행 중 · 예정 ○ 학력 · 기타

2006	2006.04 – 2009.07	Shenzhen Funful Bilingual School · 중국 선전
2009	2009.11 – 2011.10	Green Oasis School · 중국 선전
2017	2017.03 – 2020.02	상산고등학교
2021	2021.03	세종대학교 정보보호학과 입학
2023	2023.04 – 2025.01	공군 복무
2025	**2025.06 – 2025.08**	**빡공팟 13기 시스템 해킹 과정 · Elite Top 3 수료**
2026	2026.02	TOEIC 850
	2026.03 – 2026.08	**RAG-DIAG · 캡스톤 경진대회 장려상 (3등)**
	2026.08	**캐나다 UBC 블록체인 연수 · 해커톤 참가**
	2026.08	정보보안기사
	2026.08	**특허 출원 · RAG 정보 유출 취약점 진단**
	2026.09 – 현재	**SK쉴더스 루키즈 35기 클라우드 기반 스마트 융합보안 과정**
	2026.09	OPIc IH
	2026.09 – 2026.10	**보이스피싱 레이더**
	2026.10	**교육용 쇼핑몰 웹 모의침투**
2027	**2027.02**	**세종대학교 졸업 예정**

읽어 주셔서 감사합니다.

chanchan3314@naver.com 010-7406-3317 github.com/seungchan-song